



College of Computing
Cybersecurity Department

PROJECT REPORT

AI-Powered Compliance Guard for Adherence with Cybersecurity Authority Regulations in Saudi Arabia



SEC 3107

Submitted by

Student Name: Sabah Alanazi	ID: 44411937
Student Name: Aryaf Albishri	ID: 444002124
Student Name: Meaad Alzahrani	ID: 444000681
Student Name: Weaam Alzahrani	ID: 444001190

Project Supervisor: Dr. Yasmeen J. Rashidi

Project ID: S E C - 4 7 1 - P 1 - F12

December 15, 2025

Contact Information

This project report is submitted to the Department of Cybersecurity at Umm Al-Qura University in partial fulfillment of the requirements for the degree of *Bachelor of Science in Cybersecurity*.

Author(s):

Name: Sabah Alanazi
Email: 44411937@uqu.edu.sa

Name: Aryaf Albishri
Email: 444002124@uqu.edu.sa

Name: Meaad Alzahrani
Email: 444000681@uqu.edu.sa

Name: Weaam Alzahrani
Email: 444001190@uqu.edu.sa

University Supervisor(s):

Name: Dr. Yasmeen J. Rashidi
Email: yjrashidi@uqu.edu.sa

Intellectual Property Right Declaration

This is to declare that the work under the supervision of Dr. Yasmeen J. Rashidi, having the title “*AI-Powered Compliance Guard for Adherence with Cybersecurity Authority Regulations in Saudi Arabia*” and carried out in partial fulfillment of the requirements for the Bachelor of Science in Cybersecurity, is the sole property of Umm Al-Qura University and the respective supervisor. It is protected under intellectual property laws and conventions, and may only be used or extended with written permission from the University and supervisor.

This declaration applies to all students and faculty members.

Date: February 26, 2026

Author(s):

Name: Sabah Alanazi

Email: s44411937@uqu.edu.sa

Signature: _____

Name: Aryaf Albishri

Email: s444002124@uqu.edu.sa

Signature: _____

Name: Meaad Alzahrani

Email: s444000681@uqu.edu.sa

Signature: _____

Name: Weaam Alzahrani

Email: s444001190@uqu.edu.sa

Signature: _____

University Supervisor(s):

Name: Dr. Yasmeen J. Rashidi

Email: yjrashidi@uqu.edu.sa

Anti-Plagiarism Declaration

This is to declare that the publication produced under the supervision of Dr. Yasmeen J. Rashidi, titled “*AI-Powered Compliance Guard for Adherence with Cybersecurity Authority Regulations in Saudi Arabia*” is the original work of the author(s). No part of it has been reproduced illegally or plagiarized, and all referenced materials have been cited properly. The author(s) accept full responsibility for any proven violations of this declaration.

Date: February 26, 2026

Author(s):

Name: Sabah Alanazi

Email: s44411937@uqu.edu.sa

Signature: _____

Name: Aryaf Albishri

Email: s444002124@uqu.edu.sa

Signature: _____

Name: Meaad Alzahrani

Email: s444000681@uqu.edu.sa

Signature: _____

Name: Weaam Alzahrani

Email: s444001190@uqu.edu.sa

Signature: _____

University Supervisor(s):

Name: Dr. Yasmeen J. Rashidi

Email: yjrashidi@uqu.edu.sa

Acknowledgment

We express our deepest gratitude to our project supervisor, Dr. Yasmeen J. Rashidi, for her invaluable guidance, expert insights, and continuous encouragement throughout the development of the AI-Powered Compliance Guard. We also extend our sincere appreciation to the Department of Cybersecurity at Umm Al-Qura University for providing the academic foundation and resources necessary to complete this project. Furthermore, we are grateful for the regulatory frameworks provided by the National Cybersecurity Authority (NCA), specifically the Essential Cybersecurity Controls (ECC), which served as the essential benchmark for our automated compliance system. Finally, we would like to thank our families and peers for their constant support and motivation during this journey toward enhancing the cybersecurity resilience of Saudi SMEs.

Abstract

The digital transformation in Saudi Arabia aligned with Vision 2030 has increased cybersecurity risks for SMEs. Despite the National Cybersecurity Authority Essential Cybersecurity Controls (ECC), organizations face manual compliance burdens and high audit costs. This research proposes an AI-powered platform to automate cybersecurity compliance assessment focusing on Third-Party and Cloud Security controls and comparison with ISO 27001. The system provides centralized reporting, AI-assisted updates, and bilingual support. Expected outcomes include improved compliance efficiency and a scalable framework for future expansion.

Keywords— Compliance, AI, Cybersecurity Authority Regulations.

Contents

Contact Information	1
Intellectual Property Right Declaration	2
Anti-Plagiarism Declaration	4
Acknowledgment	5
Abstract	6
Table of Contents	9
List of Tables	10
List of Figures	11
1 Introduction	1
1.1 Background	1
1.2 Problem Definition & Objectives	2
1.3 Project Contribution	3
1.4 Structure of the Project	3

2	Literature Review or Related Work	5
2.1	Automated Compliance Checking Frameworks	6
2.2	Natural Language Processing for Regulatory Text	6
2.3	Regulatory Technology Applications and Saudi Governance . .	7
2.4	Summary and Comparison of Studies on Automated Compliance	8
3	Solution Approach / Methodology	11
3.1	Overall Approach	11
3.2	Methodology Details	13
3.2.1	Data Collection	15
3.2.2	Functional Requirements	16
3.2.3	Non-Functional Requirements	17
3.2.4	Sequences and Class Diagrams	17
3.2.5	Hardware and Interfaces	19
3.2.6	Prototype Design	20
3.2.7	Threat Model and Risk Analysis	21
3.3	System Modeling Diagrams	23
3.3.1	Data Flow Diagram (DFD) Level 0 (Context Diagram)	23
3.3.2	Data Flow Diagram (DFD) Level 1 (Context Diagram)	24
3.4	Operational Logic & Scenarios	25
3.4.1	Activity Diagram:	25
3.5	Security & Privacy Threat Modeling	27
3.5.1	STRIDE Model Analysis	27
3.5.2	LINDDUN Privacy Assessment	27

4	Conclusion	29
4.1	Summary of Achievements in Graduation Project 1	29
4.2	Key Findings	30
4.3	Challenges Encountered	31
4.4	Lessons Learned	31
4.5	Plans for Graduation Project 2	32
4.6	Final Summary	33

List of Tables

2.1	Summary and Comparison of Studies	8
3.1	Threat Model and Security Model	22
3.2	STRIDE Threat Model & Mitigations	27
3.3	LINDDUN Privacy Threats & Mitigations	28

List of Figures

3.1	shows the high-level workflow of the system	13
3.2	The primary sources of data	15
3.3	Sequence model	18
3.4	Class Model	19
3.5	Prototype Design	20
3.6	DFD- Level 0.	23
3.7	DFD- Level 1.	24
3.8	Activity Diagram.	26

Chapter 1

Introduction

1.1 Background

Currently, many organizations have amalgamated cyberspace solutions within their conventional business processes [1]. The more a business integrates digital solutions and increases its online presence, the more it becomes vulnerable to cybersecurity threats. Cyber attackers also took advantage of the increased online presence of many businesses to intensify their attacks [2]. Reports indicate that in Saudi Arabia, the National Cybersecurity Authority (NCA) issued the Essential Cybersecurity Controls (ECC), which is a regulatory framework to govern cybersecurity practices [3]. The ECC mandates a coordinated approach to cybersecurity, addressing critical aspects including service security, resource management, market development, user protection, and innovation support. Compliance with these controls is compulsory for all organizations operating IT systems in Saudi Arabia. Despite the availability of international standards such as ISO 2700x, PCI DSS, and NIST frameworks, these remain generic solutions that often fail to address the unique operational contexts and resource constraints characteristic of Saudi SMEs [4]. Furthermore, there is a limited amount of research in Saudi Arabia that addresses the topic of compliance with the ECC, creating a noticeable gap in the cybersecurity landscape. These challenges clearly demonstrate a persistent gap in practical, accessible compliance solutions for Saudi SMEs, which directly motivates the problem this project aims to address. This project

introduces ComplianceGuard AI, an automated cybersecurity compliance platform specifically engineered for Saudi SMEs with a critical subset of the NCA ECC.

1.2 Problem Definition & Objectives

Currently, SMEs in Saudi Arabia manage their cybersecurity and data protection compliance using fragmented and manual methods [5]. These processes are often inefficient, prone to human error, and lack continuity, especially when internal expertise is lost or consultants leave [6]. This leads to inconsistent compliance readiness and increases the likelihood of failing regulatory audits. Several studies have highlighted that many Saudi SMEs suffer from low cybersecurity awareness and a weak culture of compliance. For instance, [7] found that most SMEs lack structured cybersecurity awareness programs, reducing their ability to respond effectively to emerging threats. Similarly, [8] emphasized that SMEs face challenges in adopting cybersecurity frameworks due to limited awareness, financial constraints, and competing business priorities. Additional studies indicate that SMEs often underestimate the impact of cyber incidents [9]. This creates a false sense of security and increases exposure to severe financial and reputational consequences [10]. These findings indicate that weak awareness and a compliance culture are the main barriers to effective adherence to the ECC and PDPL (Personal Data Protection Law) of the National Cybersecurity Authority. Consequently, SMEs in Saudi Arabia rely on fragmented, manual compliance processes that are inefficient, error-prone, and lack continuity, while low cybersecurity awareness and a weak culture of compliance further undermine readiness and adherence to mandatory ECC and PDPL requirements. Coupled with the absence of supporting tools and the substantial economic losses and reputational risk caused by cyber incidents, these factors create a large compliance gap that calls for an integrated, stakeholder-driven approach that is usable within SMEs' capabilities. Addressing this gap is essential to enhance SMEs' resilience and support Saudi Arabia's Vision 2030 goal of building a secure, trusted, and innovation-driven digital economy. The primary objective of this project is to develop a web-based artificial intelligence platform that automates compliance processes for a focused set of ECC-ISO cybersecurity regulations. The system will utilize Supervised Learning to train Natural Language Processing (NLP)

models on regulatory texts, with an initial focus on the Third-Party and Cloud Security controls from the NCA ECC [11]. A core function will be to compare these controls with the relevant clauses of the ISO 27001 standard, providing organizations with insight into their local and international

1.3 Project Contribution

The main contribution of this project is: AI-driven automation, ECC- ISO mapping, continuous compliance monitoring, centralized reporting, and bilingual accessibility. These contributions were made using the development of an AI-powered platform to automate and streamline cybersecurity compliance. Unlike generic tools, the proposed platform focuses specifically on the Saudi context. The platform will provide SMEs with a tailored, that reduces the cost of compliance management, which is a major barrier for SMEs. The platform will utilize Natural Language Processing (NLP) models to analyze regulatory texts, compare them to international standards like ISO 27001, and provide a compliance score along with actionable insights. Furthermore, the platform will maintain a centralized repository of compliance reports, making it easier for SMEs to track their compliance history and remain audit-ready at all times. The bilingual (Arabic/English) support ensures that the platform is accessible to a wide range of users across Saudi Arabia, addressing the specific linguistic and regulatory needs of the country.

1.4 Structure of the Project

This report is structured as follows: Chapter 1: Introduction This chapter introduces the background of the project, defines the problem it aims to address, outlines the project's objectives, and highlights its contributions. Chapter 2: Literature Review This chapter reviews existing research on automated compliance systems, AI in cybersecurity, and regulatory frameworks, with a specific focus on their applicability to SMEs in Saudi Arabia. Chapter 3: Solution Approach / Methodology This chapter describes the methodology used to design, analyze, and develop the AI-powered compliance platform,

including system requirements, architecture, and the AI model. Chapter 4: Conclusion This chapter summarizes the key findings from the project, discusses challenges and lessons learned, and outlines future work to be undertaken in Graduation Project 2.

Chapter 2

Literature Review or Related Work

Essential Cybersecurity Controls (ECC) of the Saudi National Cybersecurity Authority establish a legal baseline for cybersecurity compliance in the Kingdom. The ECC includes 114 controls across five domains and twenty-nine subdomains focused on governance, risk management, and operational resilience [12]. The framework is broadly inclusive and well-mapped to international standards such as ISO/IEC 27001 and NIST SP 800-53. However, a major limitation is the absence of automation and digital tools to support ongoing compliance verification, requiring organizations to rely on routine audits. The NCA implementation guide complements the ECC by covering practical methods and examples of regulatory compliance [13]. It details phases of implementation, documentation required, and evidence that indicates compliance. The guide's primary benefit is its procedural detail and clarity, which helps organizations interpret and implement ECC controls. However, its prescriptive format can limit adaptability in a dynamically evolving cyber threat environment, and there is no automated mechanism for enforcing or digitally verifying compliance.

This chapter reviews the existing body of knowledge central to the development of an AI-powered compliance platform for Saudi SMEs. The related work is organized into three interconnected themes: (1) automated compliance checking frameworks, which provide foundational methodologies for rule

encoding and reasoning; (2) natural language processing (NLP) for regulatory text, which enables semantic understanding and structured extraction from unstructured documents; and (3) Regulatory Technology applications and Saudi governance considerations, which inform practical deployment and business-value realization. By examining current methodologies, this chapter establishes the basis for developing an AI-enabled platform capable of automatically mapping organizational documents to ECC requirements and facilitating continuous compliance verification.

2.1 Automated Compliance Checking Frameworks

Guo et al. [14] extend the architectural discussion by demonstrating that deep learning models augmented with Graph Neural Networks improve semantic alignment between regulatory clauses and compliance evidence. Although this approach enhances contextual understanding beyond surface-level similarity, it remains domain-specific and validated on a limited dataset, constraining generalizability. Zhang and El-Gohary [15] provide a contrasting rule-driven framework that translates extracted requirements into Horn-clause logic and ACC-tuples to enable explainable inference. While their method achieves high precision in structured regulatory environments, it depends heavily on manual rule engineering and ontology construction, limiting scalability. Collectively, these studies suggest that hybrid architectures combining neural semantic flexibility with rule-based interpretability are necessary to balance scalability, explainability, and auditability.

2.2 Natural Language Processing for Regulatory Text

Jain et al. [16] survey transformer architectures, semantic role labeling, and document classification techniques for automated compliance analysis. While the review highlights rapid methodological progress, it identifies the absence

of standardized benchmarking datasets and the limited availability of Arabic regulatory corpora. Buddhadev et al. [17] address unstructured and scanned compliance reports by integrating Optical Character Recognition (OCR), text embeddings, and Large Language Model prompting. Their approach demonstrates practical gains in handling heterogeneous formats but reveals limitations in multilingual processing and maintaining coherence in long documents.

These contributions collectively emphasize the importance of a bilingual, preprocessed NLP pipeline capable of handling both Arabic and English regulatory documents. Effective compliance automation in the Saudi context requires language detection, normalization, segmentation, and semantic alignment techniques that ensure both analytical depth and traceability.

2.3 Regulatory Technology Applications and Saudi Governance

Pappil Kothandapani and Hariharan [18] review enterprise use of Large Language Models in financial compliance, reporting scalability improvements in monitoring and anomaly detection alongside persistent issues in interpretability and legal accountability. Viracacha Peña [19] synthesizes RegTech case studies demonstrating reductions in manual review and false positives through hybrid machine learning and rule-based approaches, though large-scale empirical validation remains limited. Alfaadhel et al. [20] present the Risk-Based Cybersecurity Compliance Assessment System (RC2AS) aligned with ECC requirements, offering structured maturity scoring and visualization tools; however, the system lacks AI-driven semantic automation and extensive cross-sector validation.

Regionally focused governance and empirical studies further contextualize compliance challenges within Saudi Arabia. Rawindaran et al. [21], Alarifi [22], and the IJACSA SME study [23] document limited cybersecurity readiness, constrained financial resources, and the positive influence of awareness on compliance maturity among SMEs. Abudaqqa [24], Alzahrani [25], and Alshammari & Al-Mamary [26] analyze governance frameworks, data protection gaps, and trust dynamics influencing AI adoption. Folorunso

et al. [27] demonstrate the relationship between compliance conformance and cybersecurity performance across major frameworks, underscoring the strategic importance of automated verification mechanisms.

Collectively, these findings highlight the necessity of privacy-by-design principles, explainable AI mechanisms, cost-effective deployment models, and ECC-specific evaluation capabilities. These identified gaps motivate the development of an integrated, AI-enabled compliance platform tailored to the operational realities of Saudi SMEs.

2.4 Summary and Comparison of Studies on Automated Compliance

Table 2.1: Summary and Comparison of Studies

Ref.	Main Focus / Methodology	Key Strength	Key Limitation
[11]	Framework integrating AI, Blockchain & Smart Contracts for automated cybersecurity policy enforcement.	Demonstrated scalability, reduced manual effort, and improved response times via simulation.	Largely conceptual validation; requires real-world testing for generalizability.
[28]	Systematic review (2014–2025) of AI for crypto fraud detection using bibliometric analysis (PRISMA).	Comprehensive synthesis of 353 studies identifying key AI trends (ML, DL, NLP, GenAI).	Persistent challenges: model transparency, data access, regulatory fragmentation.
[29]	NLP tool using Sentence-BERT to extract clause-to-regulation matches for GDPR.	High effectiveness of semantic embeddings in reducing manual review effort.	Limited to English and GDPR; lacks cross-regulatory generalizability.
[16]	Literature review on NLP methodologies (transformers) for automating compliance analysis.	Strong synthesis revealing progress in NLP for compliance.	Lack of benchmarking standards and limited Arabic datasets.

Ref.	Main Focus / Methodology	Key Strength	Key Limitation
[18]	Enterprise LLM applications in financial regulation (monitoring, anomaly detection).	Demonstrates scalability in text-heavy compliance environments.	Concerns regarding transparency and legal accountability.
[14]	Deep learning & Graph Neural Networks for semantic alignment of regulations.	Captures semantic context beyond surface-level similarity.	Domain-specific; limited validation for broader regulatory sectors.
[17]	OCR, embeddings, and LLM prompting for unstructured compliance reports.	Handles heterogeneous document formats effectively.	Weak multilingual handling and long-document coherence issues.
[20]	Risk-Based Cybersecurity Compliance Assessment System (RC2AS) for Saudi ECC.	Structured quantitative maturity assessment.	Small-scale validation; lacks AI-driven automation.
[21]	Comparative cybersecurity governance study for SMEs in KSA and UK.	Valuable contextual SME insights (resources, awareness, policy uptake).	Descriptive; no technical automation mechanism.
[22]	Empirical study of Saudi SMEs using SEM on awareness and compliance.	Quantitative validation of awareness as compliance enabler.	Focuses on theory; lacks operational automation model.
[23]	Implementation of a Cybersecurity Situation Awareness Model in Saudi SMEs.	Strong sampling and readiness diagnosis.	Identifies gaps without technical solution.
[15]	Rule-based NLP with ontologies for automated compliance checking.	High precision and explainable formalization.	High engineering cost; poor scalability across domains.
[19]	Overview of RegTech compliance audits (GDPR, AML) with case studies.	Emphasis on business value and cost reduction.	Limited methodological transparency.
[24]	Documentary review on AI in Saudi IT governance (COBIT, ISO 38500).	Saudi-specific governance insights.	Relies on theoretical frameworks only.

Ref.	Main Focus / Methodology	Key Strength	Key Limitation
[26]	Quantitative survey on trust and cybersecurity awareness in AI adoption (KSA).	Clear methodological SEM approach.	Focus on consumer AI, not institutional compliance.
[25]	Legal analysis of AI data protection and regulatory gaps in Saudi Arabia.	Strong legal and regulatory perspective.	Lacks empirical implementation evidence.
[27]	Analysis of compliance conformance and firm cybersecurity performance.	Strategic comparative reflection on compliance value.	No empirical validation or automation framework.

Chapter 3

Solution Approach / Methodology

This chapter outlines the system architecture, design, and methodology for the proposed AI-Powered Compliance Guard platform. The platform aims to automate cybersecurity compliance assessments for small and medium-sized enterprises (SMEs) in Saudi Arabia, ensuring adherence to the National Cybersecurity Authority's (NCA) Essential Cybersecurity Controls (ECC). The methodology includes system design, architecture, requirements analysis, threat modeling, and security planning.

3.1 Overall Approach

The core of the proposed platform is an AI-powered system designed to automate the compliance assessment process. The system will evaluate cybersecurity controls, focusing initially on Third-Party and Cloud Security from the NCA ECC. The methodology involves collecting data from regulatory documents, preprocessing and feature extraction, developing AI models, and generating real-time compliance reports.

The platform evaluates an organization's cybersecurity compliance by processing regulatory documents, extracting meaningful features, and mapping

them to relevant ECC and ISO 27001 requirements. The system uses Natural Language Processing (NLP) to classify regulatory content and generate a numerical compliance score.

The methodology follows a linear workflow:

- **Data Collection:** This module is responsible for gathering all regulatory documents and organizational policies for compliance assessment.
- **Preprocessing & Feature Extraction Engine:** After data collection, the system performs structured preprocessing to convert raw documents into machine-readable formats.
- **AI Model:** The core analytical component applies NLP techniques and trains supervised learning models to evaluate compliance-related information.
- **Compliance Scoring Module:** This module translates the model's outputs into structured compliance insights.
- **User Interface:** The system exposes all assessments, scores, and insights through an interactive and easy-to-use interface designed for SMEs.
- **Real-time Monitoring:** The final component maintains continuous visibility over compliance status.

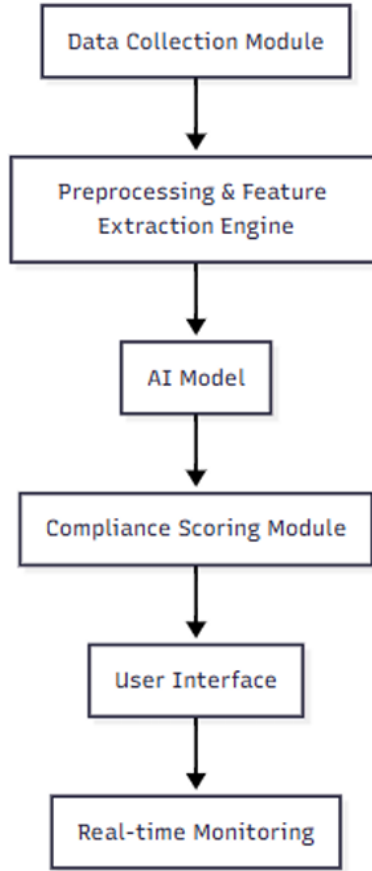


Figure 3.1: shows the high-level workflow of the system

Figure 3.1 presents the workflow starting from document collection, followed by preprocessing, model inference, compliance scoring, and report generation. The methodology integrates rule-based and AI-driven components to ensure accurate and explainable results, enabling SMEs to evaluate their cybersecurity posture efficiently.

3.2 Methodology Details

This section provides detailed steps of the project. The system architecture consists of several interconnected modules that perform ingestion, preprocess-

ing, classification, scoring, storage, and reporting.

- **Data Collection Module:** This module is responsible for gathering regulatory documents (e.g., NCA ECC and ISO 27001) and organizational compliance reports.
- **Preprocessing and Feature Extraction Engine:** This component prepares text for analysis. It performs cleaning, tokenization, language detection, Arabic normalization, and extraction of lexical, syntactic, and semantic features. It ensures that both Arabic and English content are processed consistently.
- **AI Model:** A supervised classification engine built on mBERT will be trained to evaluate compliance with the chosen cybersecurity controls. The NLP-based text-analysis pipeline uses mBERT for language-aware contextual embeddings and performs the following tasks:
 1. **OCR and layout parsing** for scanned documents.
 2. **Tokenization:** Employing a Tokenizer to transform sentences into individual words. We implemented a sequence encoder to convert each word into a numerical representation. This involves assigning a unique index to each word and replacing it with that index throughout the text. For instance, the word "how" is assigned the index 0, and wherever it appears in the text, it is replaced with 0. This process, known as tokenization, is a fundamental NLP technique for converting natural language into numerical representations.
 3. **Padding Sequences:** The pad sequences function is used to standardize the length of all sentences to 200. For example, if a sentence has a length of 100, it is padded with a specific value (usually 0) to reach the desired length of 200. This ensures that the input data has a consistent format.
- **Compliance Scoring Module:** This module aggregates predictions and applies a weighted scoring mechanism to calculate overall compliance. This will output a compliance score for organizations, with a detailed report of each control's status.

- User Interface: A dashboard providing a real-time display of compliance metrics and historical reports.

3.2.1 Data Collection

The data collection process is crucial for training the AI models. For the initial implementation phase, the system will process a focused subset of the complete regulatory and organizational dataset. Specifically, we will extract and utilize sections related to Password Policy and Risk Assessment controls from the full regulatory texts and SME reports. This targeted approach allows for deeper model accuracy and validation within these key cybersecurity domains before scaling to additional controls. The primary sources of data are illustrated in Figure 3.2.

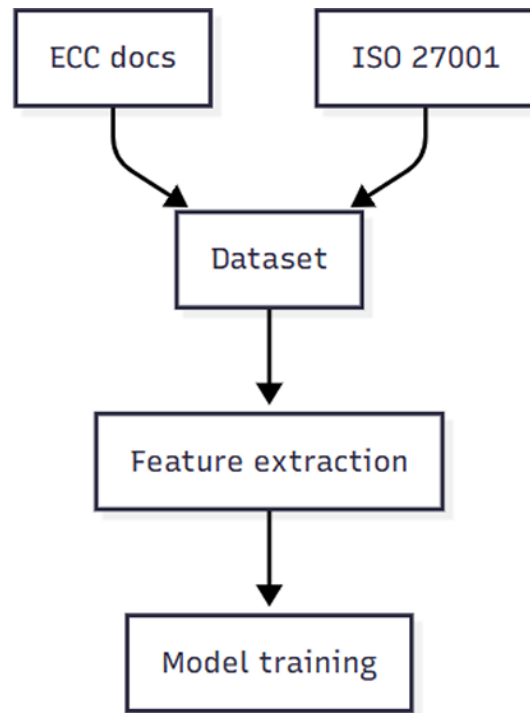


Figure 3.2: The primary sources of data

1. **Regulatory Texts:** The project will collect and analyze relevant sections of the National Cybersecurity Authority’s Essential Cybersecurity Controls (NCA ECC) and ISO 27001 that pertain to password policies and risk assessment frameworks. These specific subsets will be used to train the Natural Language Processing (NLP) models for compliance analysis, rather than processing the entire documents at this stage.
2. **SME Compliance Reports:** Historical compliance reports from SMEs in Saudi Arabia will be gathered (with permissions). From these reports, only the segments and evaluations concerning password policies and risk assessments will be extracted to validate the system’s accuracy. These focused reports will provide the ground truth for comparing the AI-generated compliance scores for the selected controls. This focused data strategy ensures efficient model development and validation for the platform’s initial core functionalities.

3.2.2 Functional Requirements

The system must support the following functions:

- **Data Ingestion:** The platform must collect and store regulatory documents and compliance reports.
- **Preprocessing and Feature Extraction:** Automatically clean, normalize, and extract relevant features from the regulatory data.
- **AI Model Training and Testing:** The system will train the AI models using labeled compliance data, test for accuracy, and optimize performance.
- **Compliance Scoring:** Once trained, the model will provide a compliance score and generate detailed compliance reports for SMEs. The compliance score is generated by aggregating per-control model predictions and validated against expert-labeled records; accuracy is measured with Precision, Recall, and F1, while confidence is calibrated, and borderline or high-risk cases are routed for expert review before deployment.

- **Real-Time Monitoring:** The system should provide real-time updates and alerts whenever changes to the compliance regulations occur.

3.2.3 Non-Functional Requirements

- **Accuracy:** The system should achieve a compliance accuracy of 85-95%, accurately identifying areas where organizations are compliant or non-compliant.
- **Scalability:** The platform must support simultaneous analysis requests from multiple SMEs and handle large document sets.
- **Performance and Low Latency:** The platform must deliver compliance assessments with minimal delay, ensuring that SMEs can quickly adjust their cybersecurity practices.
- **Reliability:** The system should be robust and provide consistent results even under varying loads.

The dynamic interactions within this architecture are further elaborated in Figure 3.3, a sequence diagram that maps the real-time chronological flow of events and data exchanges between users and the system components, from initiating an assessment to receiving the final results.

3.2.4 Sequences and Class Diagrams

The dynamic interactions within this architecture are further elaborated in Figure 3.3, a sequence diagram that maps the real-time chronological flow of events and data exchanges between users and the system components, from initiating an assessment to receiving the final results.

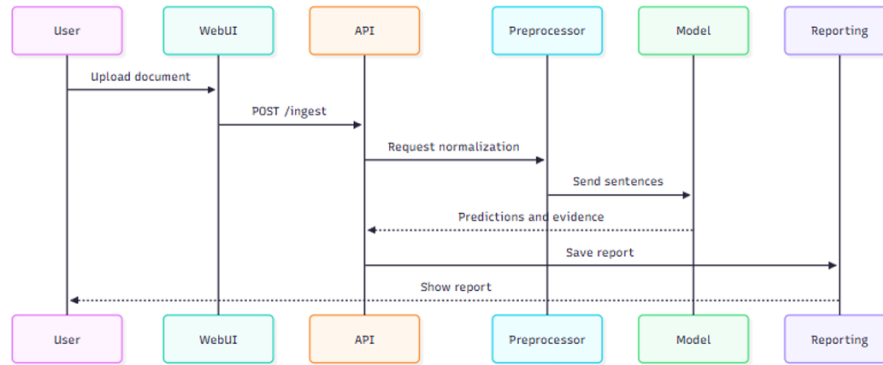


Figure 3.3: Sequence model

This diagram in Figure 3.4 defines the fundamental object-oriented building blocks of the system, the classes, their attributes, methods, and relationships, which serve as the code-level blueprint for developers. Transitioning from the backend to the user experience.

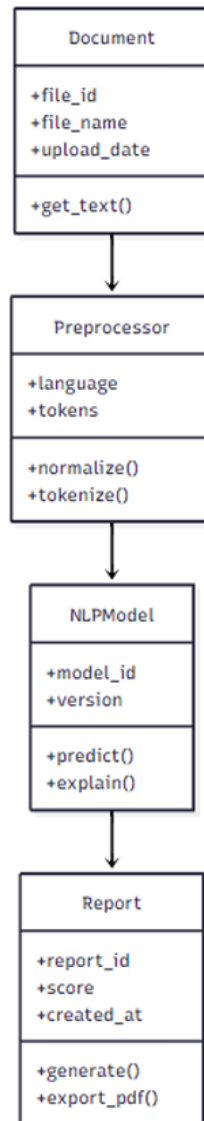


Figure 3.4: Class Model

3.2.5 Hardware and Interfaces

As this is a web-based system, the hardware requirements are minimal. However, the platform will interact with several interfaces:

- **AI and NLP Models:** These will be implemented using cloud-based infrastructure, ensuring scalability and the ability to handle large amounts of data.
- **User Devices:** The platform should be accessible from standard web browsers on desktops.
- **APIs:** Secure APIs will connect the frontend user interface with the backend AI models and databases.

3.2.6 Prototype Design

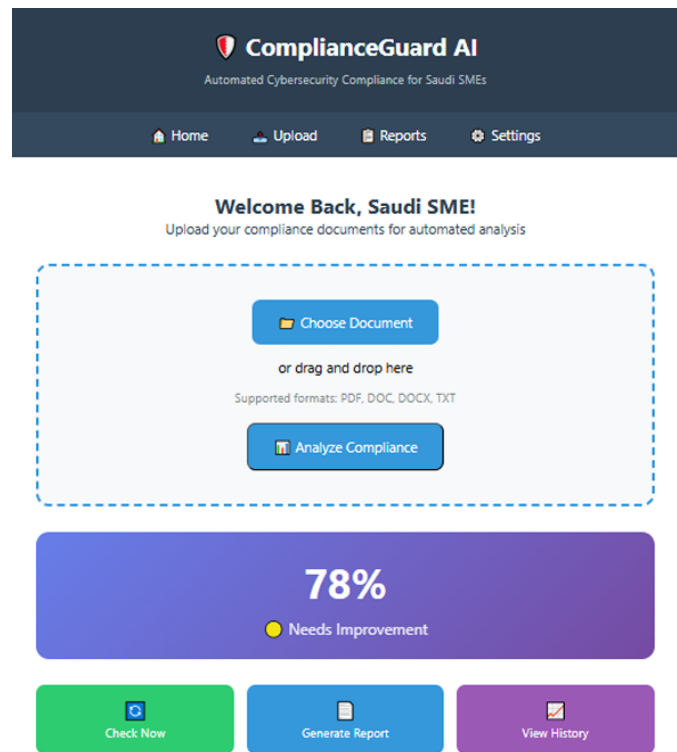


Figure 3.5: Prototype Design

A prototype of the platform will be developed during the first phase of the project. This prototype will showcase the core features, including:

- Document Upload and Compliance Assessment: Users can upload regulatory texts for automated compliance analysis.
- Compliance Dashboard: A simple, intuitive dashboard where users can see their compliance status at a glance.
- Report Generation: A feature to generate detailed reports for audits, tracking compliance over time.

Transitioning from the backend to the user experience, Figure 3.5 offers a mockup of the prototype’s user interface, giving a tangible preview of the dashboard where users will upload documents, view their compliance status, and generate detailed reports.

3.2.7 Threat Model and Risk Analysis

To ensure the robustness and resilience of the AI-Powered Compliance Guard platform, a structured Model has been developed. The Threat model proactively identifies, analyzes, and documents potential security risks that could compromise the system’s confidentiality, integrity, or availability. Each dimension was assigned a score from 1 (minimal impact) to 10 (critical impact). The overall risk score for each threat was then calculated using the average of the three scores:

$$RiskScore = (C + I + A)/3$$

The final risk level was classified based on the following ranges derived from the calculated score:

- High: 8 - 10
- Medium: 4 - 7
- Low: 1 - 3

This approach enables a more precise and transparent analysis, clearly showing how each CIA dimension is affected and providing an objective basis for prioritizing risk mitigation. By examining key threats, we define realistic attack scenarios, assess their potential business impact, and establish concrete security controls to mitigate them. Table 3.1 details this analysis.

Table 3.1: Threat Model and Security Model

Threat	Scenario	Impact	CIA Scores	Risk Level	Mitigation
Threat 1: Data Breaches	An external attacker exploits a vulnerability in the system's API or database to exfiltrate sensitive compliance data. Alternatively, an insider misuses privileges to leak reports.	Exposure of sensitive organizational data. Loss of trust and reputational damage for both the platform and the affected SME.	C: 10 I: 8 A: 6	(10+8+6)/3 = 8 High	• Data Encryption: All data at rest and in transit is encrypted using strong standards. • Strict Access Controls: Implementation of RBAC. • Monitoring & Logging: Comprehensive audit logs track activities.
Threat 2: Unauthorized Access	An attacker uses stolen, weak, or default credentials to gain access to the platform's dashboard.	Unauthorized viewing, modification, or deletion of compliance assessments. Manipulation of scores to hide gaps.	C: 9 I: 9 A: 7	(9+9+7)/3 = 8.3 High	• MFA: Mandatory for all user accounts. • Secure Session Mgt: Use of short-lived, secure session tokens with automatic logout.
Threat 3: Data Corruption	Malicious malware (e.g., ransomware) infiltrates the system and encrypts or alters stored documents and databases.	Loss of critical compliance documents and history. Generation of inaccurate compliance scores.	C: 9 I: 10 A: 8	(9+10+8)/3 = 9 High	• Automated Backups: Frequent backups to a secure, isolated environment. • Integrity Checks: Use of checksums (SHA-256) to verify document integrity.
Threat 4: Denial of Service	Attackers overload the system API.	Attack making the service unavailable.	C: 2 I: 3 A: 10	(2+3+10)/3 = 5.0 Medium	• Rate limiting • Load balancing • Firewalls • System monitoring and alerting.
Threat 5: Privacy Leakage	Generated reports unintentionally expose sensitive or personal information.	Expose sensitive or personal information.	C: 4 I: 3 A: 2	(4+3+2)/3 = 3.0 Low	• Data minimization • Masking sensitive fields • Compliance checks before report generation.

This chapter describes the design and methodology for the AI-powered ComplianceGuard AI platform. The system architecture was outlined, detailing how the system will automate cybersecurity compliance assessments

for SMEs in Saudi Arabia. The functional and non-functional requirements were defined to ensure that the platform will be effective, scalable, and secure. Additionally, the threat and security models highlight potential risks and the measures in place to mitigate them. The next steps involve implementing the system and conducting testing, which will be discussed in the following chapter.

3.3 System Modeling Diagrams

3.3.1 Data Flow Diagram (DFD) Level 0 (Context Diagram)

Diagram in Figure 3.6 shows Data Flow Diagram (DFD) Level 0 for the system's interactions with external entities.

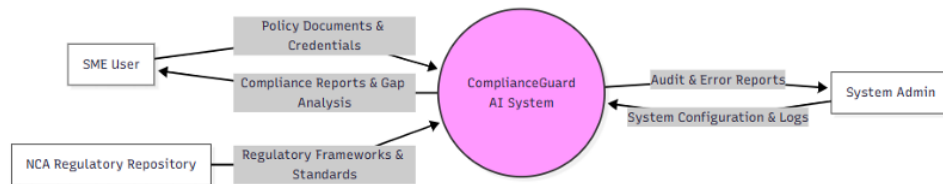


Figure 3.6: DFD- Level 0.

External Entities: SME User, System Admin, and National Cybersecurity Authority (NCA) Regulatory Repository.

Process: ComplianceGuard AI System.

Data Flows: The User sends "Policy Documents" and "Credentials" to the system; the system sends "Compliance Reports" and "Gap Analysis" back to the User.

3.3.2 Data Flow Diagram (DFD) Level 1 (Context Diagram)

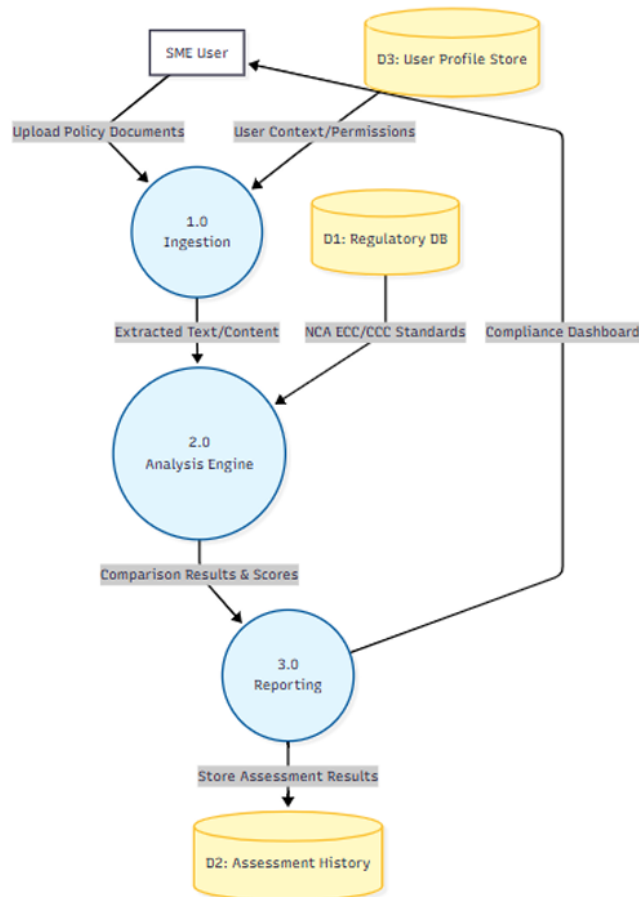


Figure 3.7: DFD- Level 1.

The DFD Level 1 provides a functional decomposition of the system into three core processes and three specialized data stores:

- Process 1.0 (Ingestion): This process serves as the entry point for the system. It receives raw policy documents from the SME User. It interacts with the User Profile Store (D3) to verify the user's identity

and permissions before extracting and cleaning the text for the next stage.

- Process 2.0 (Analysis Engine): This is the "brain" of the system. It takes the cleaned text from the Ingestion process and utilizes mBERT or NLP models to perform semantic matching. It queries the Regulatory DB (D1) to fetch specific clauses from the NCA ECC/CCC frameworks, comparing the uploaded policy against these standards to identify compliance levels.
- Process 3.0 (Reporting): The final process aggregates the comparison results and numerical scores from the Analysis Engine. It generates a visual representation of the data, which is sent back to the User as a dashboard or downloadable report. Simultaneously, it updates the Assessment History (D2) so that the SME can track their compliance progress over time.

3.4 Operational Logic & Scenarios

This section demonstrates the system in action.

3.4.1 Activity Diagram:

- User Login: Authenticate using local credentials.
- Upload Document: SME employee uploads a "Password Policy."
- Pre-processing: System extracts text.
- AI Analysis: The system identifies if the policy meets the policy in NSA.

- Output: Display a "Compliant" or "Non-Compliant" status with specific remediation steps.

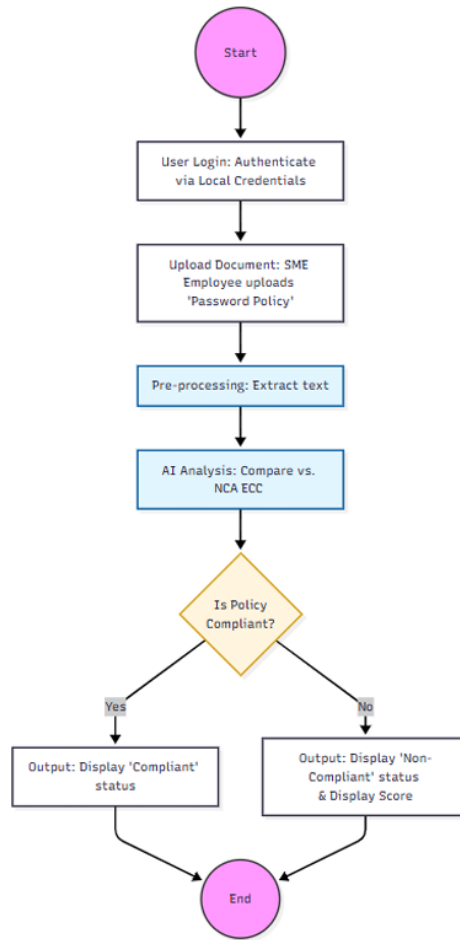


Figure 3.8: Activity Diagram.

Scenario: A small IT firm in Riyadh wants to ensure its "Remote Access Policy" complies with NCA regulations. They upload their document; the AI identifies a missing section on "Multi-Factor Authentication" (MFA) and flags it as a critical gap.

Case Study: Application for a Saudi SME. By using the tool, the SME

reduces its manual audit time from 2 weeks to 10 minutes, ensuring 100% alignment with the latest ECC-2 updates.

3.5 Security & Privacy Threat Modeling

3.5.1 STRIDE Model Analysis

STRIDE is applied to identify critical threats to the system's security.

Table 3.2: STRIDE Threat Model & Mitigations

Threat Category	Example in System	Mitigation
Spoofing	Fake admin login to alter reports	Multi-factor authentication (MFA), strong session management
Tampering	Unauthorized alteration of compliance data	Digital signatures and integrity checks (SHA-256)
Repudiation	User denies submitting a document	Maintain immutable audit logs of all uploads and assessment actions.
Information Disclosure	Leak of SME compliance reports	Encryption (Use AES-256 encryption for data at rest)
Denial of Service	API overload by a malicious actor	Implement rate limiting and request size validation at the API gateway.
Elevation of Privilege	User gains admin rights illegally	Enforce strict Role-Based Access Control (RBAC) (Principle of least privilege)

3.5.2 LINDDUN Privacy Assessment

Since the system handles sensitive organizational data, a LINDDUN assessment is critical for Saudi PDPL (Personal Data Protection Law) compliance.

Table 3.3: LINDDUN Privacy Threats & Mitigations

Privacy Threat	Description	Mitigation
Linkability	Attacker links anonymized reports to specific SME	Data aggregation, avoid direct identifiers
Identifiability	Personal info exposed in compliance documents	Automated PII detection & redaction, masking of sensitive fields
Non-repudiation	SME denies data ownership	Implement detailed access logs with timestamping and user ID tracking.
Detectability	Attacker detects that an SME uses the system	Encrypt the "Risk Score" results and only show them to authorized personnel.
Disclosure of Info	Unintended data exposure via APIs/reports	Enforce strict data retention policies; delete uploaded files after analysis.
Unawareness	Users unaware of how their data is used/stored	Provide a clear Privacy Policy and obtain explicit consent before analysis.
Non-compliance	System violates PDPL (Saudi data law) or GDPR	Ensure all data is hosted on local Saudi cloud providers

Chapter 4

Conclusion

This chapter summarizes what was accomplished during Graduation Project 1, highlights the most significant findings, reflects on the technical and project-level challenges encountered, and outlines the planned work for Graduation Project 2. The conclusions presented here are derived directly from the system design, prototype specifications, and evaluation scope described throughout this report.

4.1 Summary of Achievements in Graduation Project 1

First, a comprehensive problem definition was established. The cybersecurity compliance landscape in Saudi Arabia was analyzed in depth, identifying a critical gap faced by SMEs in adhering to the National Cybersecurity Authority's (NCA) Essential Cybersecurity Controls (ECC). The analysis demonstrated that current compliance practices are largely manual, costly, and inefficient, creating operational and regulatory risks.

Second, clear objectives and scope boundaries were defined. The project's primary objective was formalized as the development of a web-based AI platform that automates compliance assessment for a focused subset of ECC

controls, maps them to ISO 27001 requirements, and provides bilingual (Arabic/English) support. Limiting the scope to specific control domains enabled a realistic and technically feasible first-phase design.

Third, an extensive literature review was conducted, covering automated compliance frameworks, Natural Language Processing (NLP) for regulatory text analysis, and Regulatory Technology (RegTech) applications. This review validated the novelty of addressing ECC-aligned compliance automation within the Saudi SME context and directly informed the selected hybrid rule-neural technical approach.

Fourth, a detailed methodology and system architecture were developed. The proposed solution architecture clearly defined the workflow from data ingestion and bilingual preprocessing to AI inference, compliance scoring, and dashboard visualization. Functional and non-functional requirements were specified, and preliminary security and threat considerations were identified.

Finally, prototype planning and visualization were completed. Architectural diagrams, sequence diagrams, class models, and user interface mockups were designed to provide a clear blueprint for future implementation. These artifacts collectively represent a robust design phase and establish a strong theoretical and architectural foundation for the ComplianceGuard AI platform.

4.2 Key Findings

A significant regulatory gap exists in the Saudi SME ecosystem. There is a shortage of affordable, automated tools specifically designed to assist organizations in achieving and maintaining compliance with the NCA ECC. This gap increases exposure to regulatory penalties and cybersecurity incidents.

SME constraints were identified as a major barrier to compliance. Limited financial resources, insufficient cybersecurity awareness, and a lack of in-house expertise restrict SMEs' ability to effectively implement and sustain generic international frameworks such as ISO 27001 without external consultancy support.

The integration of AI and NLP technologies, particularly supervised learning models with bilingual capabilities, was identified as a viable and scalable solution. Automating the semantic analysis of regulatory controls and organizational documents can significantly reduce manual effort, improve consistency, and enhance compliance readiness.

4.3 Challenges Encountered

Data availability represents a primary challenge. Obtaining a sufficient volume of real, anonymized SME compliance documents for training and validating supervised NLP models remains difficult due to confidentiality and data-sharing restrictions.

Linguistic complexity is another major challenge. Designing an NLP pipeline capable of accurately processing both formal Arabic regulatory language and English technical standards requires advanced preprocessing, normalization, and domain-specific modeling techniques.

Defining quantitative compliance metrics also proved complex. Translating qualitative regulatory requirements into a standardized, weighted scoring model that fairly represents an organization’s cybersecurity posture involves careful modeling decisions and validation strategies.

Finally, balancing usability with analytical depth is critical. The platform must remain accessible to SMEs with limited technical staff while simultaneously delivering meaningful insights for cybersecurity professionals and auditors.

4.4 Lessons Learned

The project operates at the intersection of cybersecurity, artificial intelligence, regulatory policy, and system design. Effective progress requires integrating insights from these domains rather than treating them independently.

Accurate interpretation of ECC and ISO 27001 controls is a prerequisite for any reliable AI-driven compliance assessment. Misinterpretation at the regulatory level would compromise the validity of the entire system.

Scope control proved essential. Narrowing the focus to a subset of ECC controls enabled meaningful architectural progress and prevented overextension during the initial phase.

Regulatory understanding must precede technical design. Establishing a clear conceptual mapping between regulatory clauses and measurable indicators is necessary before implementing automated models.

Prototyping served as a powerful communication mechanism. Early architectural and interface visualizations facilitated alignment within the development team and improved clarity when presenting the concept to stakeholders.

4.5 Plans for Graduation Project 2

The first major task will involve structured data collection and labeling. This includes curating and annotating ECC and ISO 27001 documents, as well as acquiring and labeling a diverse set of SME compliance artifacts in both Arabic and English. A properly constructed validation dataset will be essential for supporting accuracy claims.

The second task will focus on model implementation and optimization. Supervised NLP models for control classification and ECC–ISO mapping will be implemented, trained, and tuned. Hyperparameter optimization will target the predefined performance range of 85–95% accuracy.

The third task involves full-stack prototype development. A functional web-based application integrating backend AI modules and frontend dashboard components will be implemented. This includes real-time compliance scoring, interactive visualization, and downloadable audit trail reporting features.

The fourth task will involve evaluation and user testing. Quantitative evaluation metrics such as precision, recall, and end-to-end compliance scoring accuracy will be measured. Additionally, qualitative usability testing will be conducted with selected SME representatives and domain experts to collect feedback and guide iterative refinement.

4.6 Final Summary

Key technical, linguistic, and data-related challenges were identified, forming the basis of a focused and actionable implementation plan for Graduation Project 2. The upcoming phase will transition the project from conceptual design to an implemented and evaluated system. Through structured data preparation, model development, secure system integration, and empirical validation, the platform aims to become a demonstrable solution capable of assisting SMEs in maintaining continuous, measurable, and auditable compliance with Saudi cybersecurity regulations.

References

- [1] Y. Li and Q. Liu. (2021) A comprehensive review study of cyberattacks and cyber security: Emerging trends and recent developments. *Energy Rep.* [Online]. Available: <https://doi.org/10.1016/j.egy.2021.11.023>. [Accessed: Oct. 26, 2025].
- [2] S. AlDaajeh, H. Saleous, S. Alrabae, E. Barka, F. Breiting, and K. Raymond Choo. (2022) The role of national cybersecurity strategies on the improvement of cybersecurity education. *Comput. Secur.* [Online]. Available: <https://doi.org/10.1016/j.cose.2022.102754>. [Accessed: Oct. 26, 2025].
- [3] National Cybersecurity Authority (NCA). (2018) Essential cybersecurity controls (ecc-1: 2018). NCA Portal. [Online]. Available: <https://nca.gov.sa/files/ecc-en.pdf>. [Accessed: Oct. 20, 2025].
- [4] M. M. Alshammari and Y. H. Al-Mamary. (2025) Building trust and cybersecurity awareness in saudi arabia. *Systems.* [Online]. Available: <https://doi.org/10.3390/systems13100863>. [Accessed: Oct. 26, 2025].
- [5] R. Alzahrani. (2024) An overview of ai data protection in the context of saudi arabia. *IJSR.* [Online]. Available: <https://doi.org/10.59992/IJSR.2024.v3n3p8>. [Accessed: Oct. 26, 2025].
- [6] A. Folorunso, I. Wada, B. Samuel, and V. Mohammed. (2024) Security compliance and its implication for cybersecurity. *World Journal of Advanced Research and Reviews.* [Online]. Available: <https://doi.org/10.30574/wjarr.2024.24.1.3170>. [Accessed: Oct. 26, 2025].
- [7] M. F. Almoaigel and A. Abuabid. (2023) Implementation of cybersecurity situation awareness model in saudi smes. *International Journal*

- of Advanced Computer Science and Applications (IJACSA). [Online]. Available: <https://thesai.org/Publications/IJACSA>. [Accessed: Oct. 26, 2025].
- [8] N. Rawindaran, L. Nawaf, S. Alarifi, D. Alghazzawi, F. Carroll, I. Katib, and C. Hewage. (2023) Enhancing cyber security governance and policy for smes in industry 5.0: A comparative study between saudi arabia and the united kingdom. Digital. [Online]. Available: <https://doi.org/10.3390/digital3030014>. [Accessed: Oct. 26, 2025].
 - [9] A. Alotaibi *et al.* (2021) The impact of cybersecurity practices on cyberattack damage in small enterprises in saudi arabia. ResearchGate. [Online]. Available: <https://www.researchgate.net/>. [Accessed: Oct. 26, 2025].
 - [10] S. Perera, X. Jin, A. Maurushat, and D. Opoku. (2022) Factors affecting reputational damage to organisations due to cyberattacks. Informatics. [Online]. Available: <https://doi.org/10.3390/informatics9020028>. [Accessed: Oct. 26, 2025].
 - [11] L. Alevizos and V. Ta. (2024) Automated cybersecurity compliance and threat response using ai, blockchain & smart contracts. arXiv. [Online]. Available: <https://doi.org/10.48550/arXiv.2409.08390>. [Accessed: Oct. 26, 2025].
 - [12] National Cybersecurity Authority (NCA). (2018) Essential cybersecurity controls (ecc). NCA Portal. [Online]. Available: <https://nca.gov.sa/ecc-en.pdf>. [Accessed: Oct. 26, 2025].
 - [13] ——. (2018) Guide to ecc implementation. NCA Portal. [Online]. Available: <https://cdn.nca.gov.sa/index/Guide-to-ECC-Implementation.pdf>. [Accessed: Oct. 26, 2025].
 - [14] H. Guo, B. An, Z. Guo, and Z. Su. (2020) Deep semantic compliance advisor for unstructured document compliance checking. IJCAI 2020. [Online]. Available: <https://doi.org/10.24963/ijcai.2020/607>. [Accessed: Oct. 26, 2025].
 - [15] J. Zhang and N. El-Gohary. (2015) Semantic nlp-based information extraction for automated compliance checking. ASCE Journal of Com-

- puting in Civil Engineering. [Online]. Available: [https://doi.org/10.1061/\(ASCE\)CP.1943-5487.0000346](https://doi.org/10.1061/(ASCE)CP.1943-5487.0000346). [Accessed: Oct. 26, 2025].
- [16] Jain *et al.* (2025) Ai/nlp’s role in regulatory compliance. ACL Findings. [Online]. Available: <https://aclanthology.org/2025.findings-acl.1366.pdf>. [Accessed: Oct. 26, 2025].
 - [17] Buddhadev *et al.* (2025) Automated compliance checking of unstructured data using llms and langchain. MMEP. [Online]. Available: <https://doi.org/10.18280/mmep.120927>. [Accessed: Oct. 26, 2025].
 - [18] H. Pappil Kothandapani and Hariharan. (2025) Ai-driven regulatory compliance: Transforming financial oversight through llms. Figshare. [Online]. Available: <https://doi.org/10.6084/m9.figshare.28251608>. [Accessed: Oct. 26, 2025].
 - [19] J. Viracacha Peña. (2024) Artificial intelligence in regtech: Transforming automated compliance audits. SSRN. [Online]. Available: <https://ssrn.com/abstract=5176055>. [Accessed: Oct. 26, 2025].
 - [20] A. Alfaadhel, I. Almomani, and M. Ahmed. (2023) Risk-based cybersecurity compliance assessment system (rc2as). Applied Sciences. [Online]. Available: <https://doi.org/10.3390/app13106145>. [Accessed: Oct. 26, 2025].
 - [21] Rawindaran *et al.* (2023) Enhancing cyber security governance and policy for smes in industry 5.0: Saudi arabia vs uk. Digital. [Online]. Available: <https://doi.org/10.3390/digital3030014>. [Accessed: Oct. 26, 2025].
 - [22] S. Alarifi. (2023) Small and medium businesses readiness towards cyberattacks in saudi arabia. Global Economics Review (GER). [Online]. Available: [https://doi.org/10.31703/ger.2023\(VIII-I\)](https://doi.org/10.31703/ger.2023(VIII-I)). [Accessed: Oct. 26, 2025].
 - [23] The SAI Organization. (2023) Implementation of a cybersecurity situation awareness model in saudi smes. IJACSA. [Online]. Available: https://thesai.org/Downloads/Volume14No11/Paper_110-Implementation_of_Cybersecurity_Situation_Awareness_Model.pdf. [Accessed: Oct. 26, 2025].

- [24] F. Abudaqqa. (2025) Artificial intelligence for it governance in saudi arabia. *European Scientific Journal*. [Online]. Available: <https://eujournal.org/>. [Accessed: Oct. 26, 2025].
- [25] R. Alzahrani. (2024) An overview of ai data protection in the context of saudi arabia. *IJSR*. [Online]. Available: <https://doi.org/10.59992/IJSR.2024.v3n3p8>. [Accessed: Oct. 26, 2025].
- [26] M. M. Alshammari and Y. H. Al-Mamary. (2025) Building trust and cybersecurity awareness in saudi arabia. *Systems*. [Online]. Available: <https://doi.org/10.3390/systems13100863>. [Accessed: Oct. 26, 2025].
- [27] Folorunso *et al.* (2024) Compliance conformance and firm cybersecurity performance. *WJARR*. [Online]. Available: <https://doi.org/10.30574/wjarr.2024.24.1.3170>. [Accessed: Oct. 26, 2025].
- [28] L. Rodríguez Valencia *et al.* (2025) A systematic review of artificial intelligence applied to compliance: Fraud detection in cryptocurrency transactions. *Journal of Risk and Financial Management*. [Online]. Available: <https://doi.org/10.3390/jrfm1811061>. [Accessed: Oct. 26, 2025].
- [29] Amaral *et al.* (2022) Nlp-based automated compliance checking of data processing agreements against gdpr. *arXiv*. [Online]. Available: <https://arxiv.org/pdf/2209.09722>. [Accessed: Oct. 26, 2025].